

Secure RAG Architecture Review Checklist

Review authorization before model access—then evaluate token efficiency with answer quality.

1. Identity and tenant isolation

- ☐ Verified end-user and workload identities are propagated.
- ☐ Tenant boundaries exist in storage, retrieval, and authorization.
- ☐ Cache scope includes identity, tenant, policy, and source state.
- ☐ Cross-user, agent, and tenant attempts are tested.

2. Retrieval authorization

- ☐ Retrieved chunks are candidates, not authorization grants.
- ☐ Identity, task, path, environment, sensitivity, and freshness are checked.
- ☐ Policy runs outside the model before prompt construction.
- ☐ Denied content is never echoed in model-visible responses.

3. Fail-closed behavior

- ☐ An empty authorized result produces empty model context.
- ☐ No unrestricted retrieval fallback exists.
- ☐ Model output cannot override a denial.
- ☐ Recovery uses a separate authorized workflow.

4. Injection and credentials

- ☐ Retrieved text is treated as untrusted data.
- ☐ Direct and indirect prompt injection are tested.
- ☐ Source, index, and gateway credentials stay outside prompts.
- ☐ Tool-action authorization is a separate control.

5. Provenance and freshness

- ☐ References, hashes, versions, and parser versions are retained.
- ☐ Capsules expire and freshness thresholds are explicit.
- ☐ Source or policy changes invalidate affected cache entries.
- ☐ Release and denial records can be replayed.

6. Evaluation evidence

- ☐ Full-approved, retrieval-only, and secure-RAG paths use identical tasks.
- ☐ Provider usage—not word estimates—supports production cost claims.
- ☐ Failures, exclusions, model, policy, source, and task versions are retained.
- ☐ Independent and project-controlled results are labeled separately.

Predefine acceptance gates before testing

Required-fact recall
Target: _____

Reviewer acceptance
Target: _____

False positives
Maximum: _____

Prohibited releases
Maximum: 0